

TryHackMe Write-Up

ItsyBitsy — Threat Hunting with Kibana & Elastic Stack

Difficulty: Easy | Category: Threat Hunting | Platform: TryHackMe

Room Overview

This challenge simulates a real-world SOC scenario where a security analyst must investigate network connection logs using Kibana and the Elastic Stack. The objective is to identify suspicious activity and uncover a hidden flag by following network-based indicators of compromise.

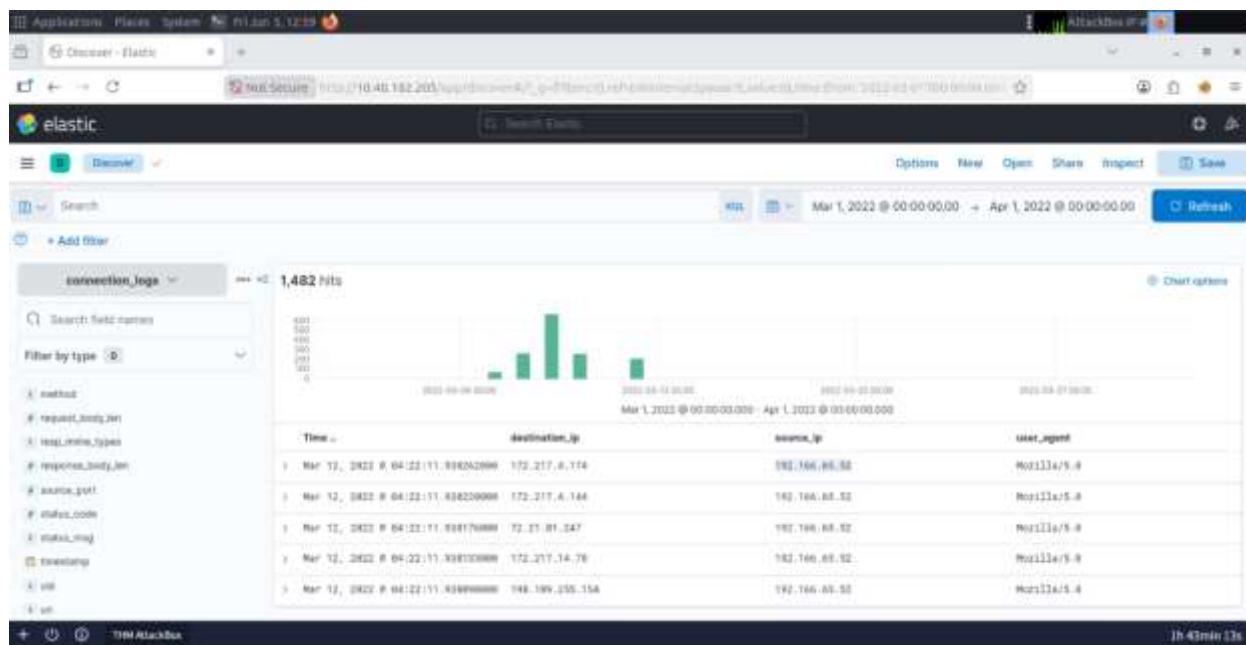
Platform	TryHackMe
Room Name	ItsyBitsy
Category	Threat Hunting
Difficulty	Easy
Tools Used	Kibana, Elastic Stack (ELK)
Log Index	connection_logs
Total Log Records	1,482

Step 1 — Initial Log Analysis

Upon opening Kibana, I was presented with the connection_logs index containing 1,482 records spanning March 1 to April 1, 2022. I began by familiarising myself with the available fields before filtering for anomalies.

Key Fields Examined

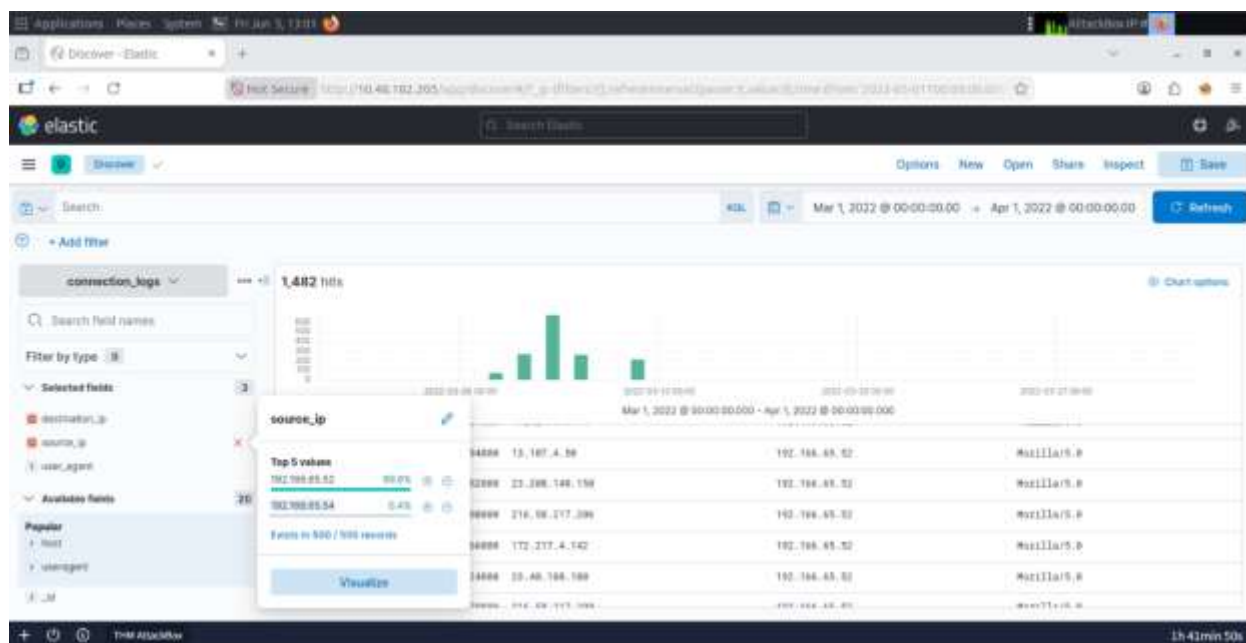
- source_ip — originating host of each connection
- destination_ip — remote endpoint receiving the connection
- user_agent — application or process making the request
- uri — resource path requested at the destination
- timestamp — date and time of the network event



The dashboard displays all connection logs collected between March 1 and April 1, 2022. At this stage, I began reviewing network activity to identify anomalies.

Step 2 — Investigating Source IP Addresses

To identify suspicious hosts, I added the source_ip field to the Kibana data table and examined the top value distribution.



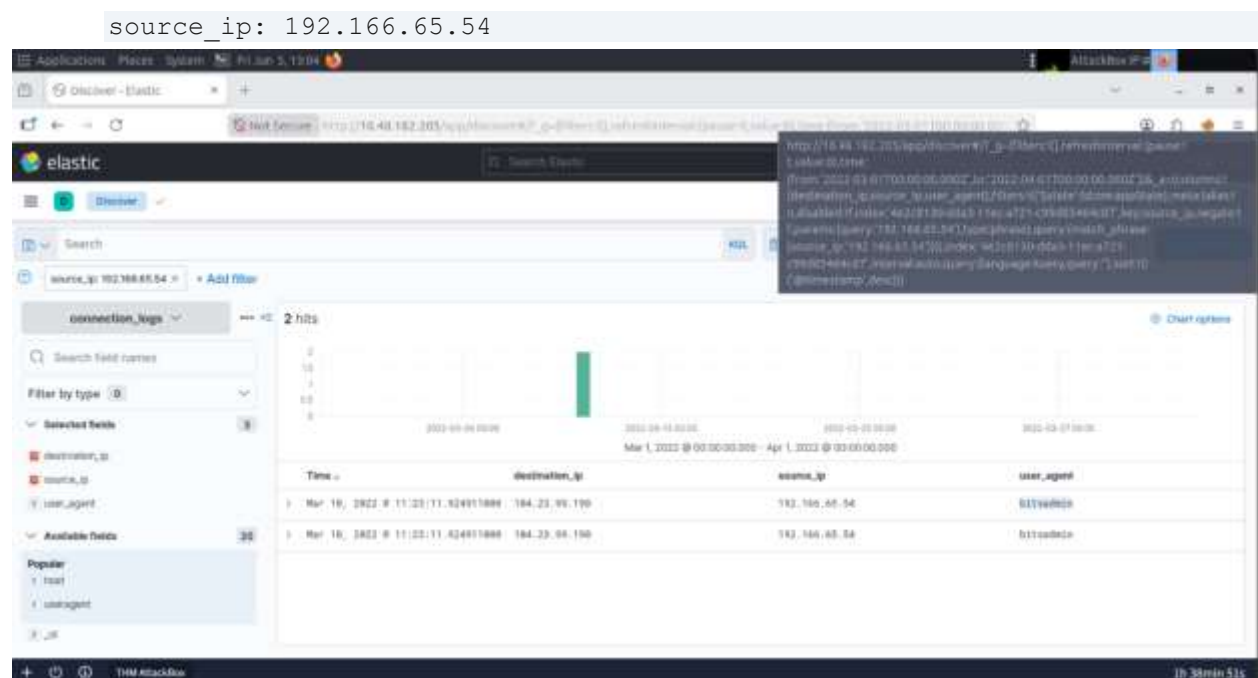
Traffic Distribution

- 192.166.65.52 — responsible for 99.6% of all connection records (normal baseline traffic)
- 192.166.65.54 — responsible for only 0.4% of records (anomalous outlier)

Due to its extremely low volume of connections, 192.166.65.54 was immediately flagged as the primary suspect for further investigation. In threat hunting, low-frequency outliers often indicate stealthy malicious activity designed to blend in with legitimate traffic.

Step 3 — Filtering the Suspicious IP

I applied the following Kibana query to isolate all records associated with the suspicious source IP:



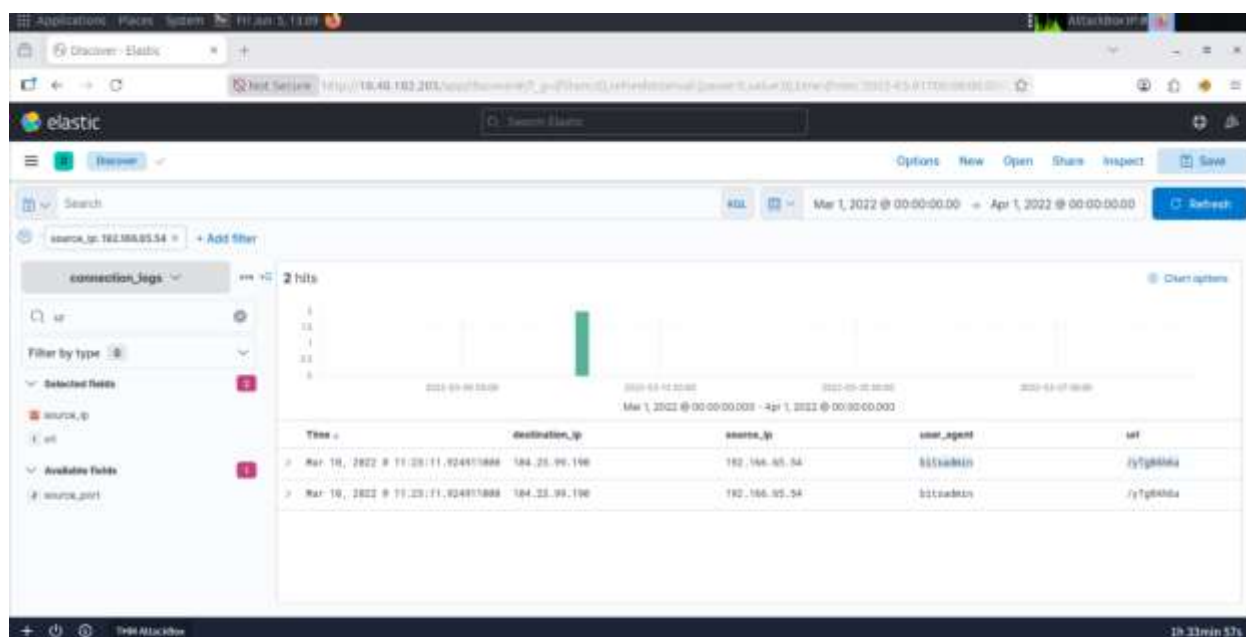
This filter returned only two records. The key findings from these records are summarised below.

Field	Value
Source IP	192.166.65.54
Destination IP	104.23.99.190
User Agent	bitsadmin

The presence of bitsadmin immediately stood out because it is commonly abused for file transfers and malicious downloads.

Step 4 — Investigating the URI

Next, I added the uri field to the Kibana results table to reveal what resource was being requested by the suspicious host.



URI: /yTg0Ah6a

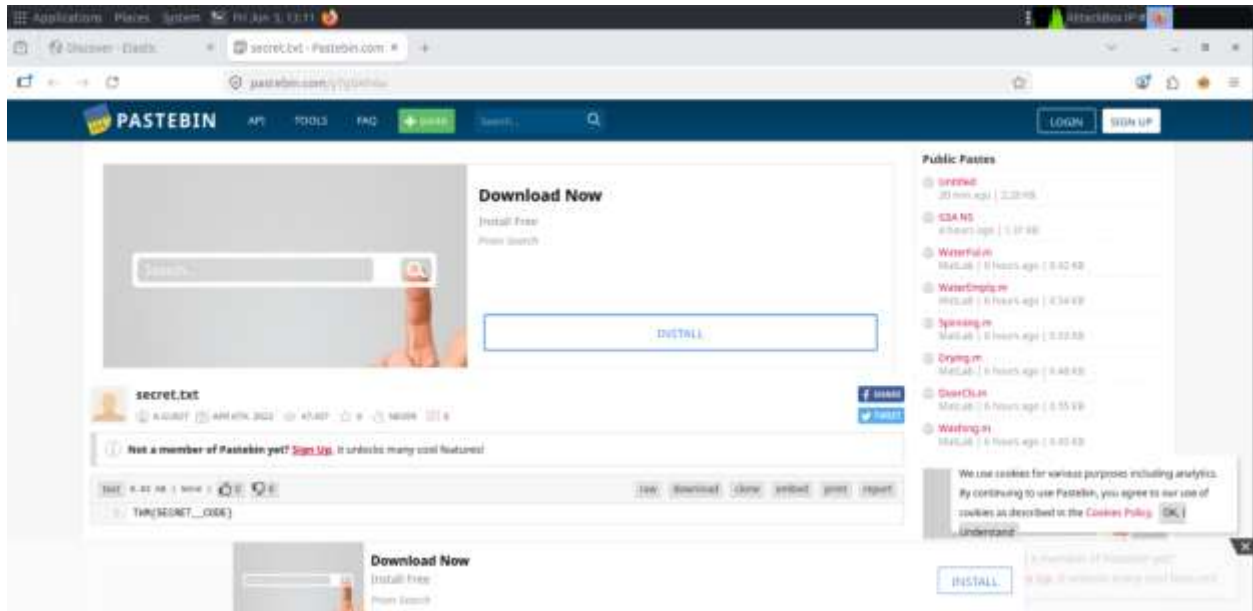
Correlating this short URI with the destination IP (104.23.99.190), which resolves to Pastebin infrastructure, strongly suggested that the endpoint was communicating with a Pastebin paste. This is a common technique used for command-and-control (C2) staging or data exfiltration, where adversaries host configuration files, payloads, or instructions on public paste services to evade detection.

Step 5 — Following the Indicator

Following the network indicator, I navigated to the full reconstructed URL:

```
https://pastebin.com/yTg0Ah6a
```

The Pastebin page contained the challenge flag, confirming that the suspicious host had successfully communicated with an external paste service — a clear indicator of potential data staging or exfiltration activity.



Flag: THM{SECRET_CODE}

Key Indicators of Compromise (IOCs)

The following network-based IOCs were identified throughout this investigation:

IOC Type	Value
Source IP	192.166.65.54
Destination IP	104.23.99.190
User Agent	bitsadmin
Malicious URI	/yTg0Ah6a
Full URL	https://pastebin.com/yTg0Ah6a

MITRE ATT&CK Mapping

The observed behaviour maps to the following MITRE ATT&CK techniques:

Technique ID	Description
T1105	Ingress Tool Transfer — using BITSAdmin to download files or payloads from an external source
T1218	Signed Binary Proxy Execution — leveraging a trusted Windows binary (bitsadmin.exe) to evade detection
T1567	Exfiltration Over Web Service — communicating with a public paste service (Pastebin) for C2 or staging

Lessons Learned

This room reinforced several key concepts applicable to real-world SOC and threat hunting workflows:

- Log analysis at scale using Kibana and the Elastic Stack (ELK)
- Anomaly detection through traffic volume analysis — low-frequency outliers are often high-value leads
- Recognition of living-off-the-land (LOTL) binaries such as bitsadmin as threat indicators
- Following the full chain of network indicators from IP to URI to external resource
- Understanding how adversaries abuse legitimate web services like Pastebin for C2 infrastructure
- Applying MITRE ATT&CK techniques to observed network behaviour
- Practical application of a structured SOC analyst investigation workflow

Conclusion

The ItsyBitsy room provided an excellent introduction to network-based threat hunting using Kibana. By identifying a low-volume anomalous source IP, recognising a suspicious user agent (bitsadmin), and tracing the network indicator to an external Pastebin URL, I was able to reconstruct a realistic threat scenario involving living-off-the-land techniques and potential C2 staging via a public web service.

This type of investigation reflects the day-to-day workflow of a SOC analyst — filtering noise, identifying outliers, and following indicators through to their conclusion — making it a valuable hands-on exercise for anyone pursuing a career in blue team security or threat intelligence.

— *End of Write-Up* —